AUTHENTICATION

SECURE WEB DEVELOPMENT

Outline

- General Guidelines
- Logging and Monitoring
- Use of authentication protocols that require no password

Outline

- **General Guidelines**
- Logging and Monitoring
- Use of authentication protocols that require no password

Outline

- General Guidelines
- **Logging and Monitoring**
- Use of authentication protocols that require no password

Outline

- General Guidelines
- Logging and Monitoring
- **Use of authentication protocols that require no password**

Authentication is the process of verification that an individual, entity, or website is who it claims to be.

Authentication in the context of web applications is commonly performed by submitting a username or ID and one or more items of private information that only a given user should know.

Image source: https://securityintelligence.com/wp-content/uploads/2018/03/fingerprintpasswordbiome_553981-630x330.jpg

Authentication is the process of verification that an individual, entity, or website is who it claims to be.

Authentication in the context of web applications is commonly performed by submitting a username or ID and one or more items of private information that only a given user should know.

Image source: https://securityintelligence.com/wp-content/uploads/2018/03/fingerprintpasswordbiome_553981-630x330.jpg

Authentication is the process of verification that an individual, entity, or website is who it claims to be.

Authentication in the context of web applications is commonly performed by submitting a username or ID and one or more items of private information that only a given user should know.

Image source: https://securityintelligence.com/wp-content/uploads/2018/03/fingerprintpasswordbiome_553981-630x330.jpg

General Guidelines

User ID

- **Make sure your usernames/user IDs are case insensitive.**
  - User 'smith' and user 'Smith' should be the same user.
- Usernames should also be unique.
- For high security applications usernames could be assigned and secret instead of user-defined public data.

User ID

- Make sure your usernames/user IDs are case insensitive.
  - User 'smith' and user 'Smith' should be the same user.
- **Usernames should also be unique.**
- For high security applications usernames could be assigned and secret instead of user-defined public data.

User ID

- Make sure your usernames/user IDs are case insensitive.
  - User 'smith' and user 'Smith' should be the same user.
- Usernames should also be unique.
- **For high security applications usernames could be assigned and secret instead of user-defined public data.**

User ID

If you are to use the email address as the user ID, make sure to properly validate the input before accepting it.

local

juandlc@email.com

domain

Implement Proper Password Strength Controls

- A key concern when using passwords for authentication is password strength.
- A "strong" password policy makes it difficult or even improbable for one to guess the password through either manual or automated means.

Implement Proper Password Strength Controls

- **A key concern when using passwords for authentication is password strength.**
- A "strong" password policy makes it difficult or even improbable for one to guess the password through either manual or automated means.

Implement Proper Password Strength Controls

- A key concern when using passwords for authentication is password strength.
- **A "strong" password policy makes it difficult or even improbable for one to guess the password through either manual or automated means.**

Implement Proper Password Strength Controls

Consider the following:

- Password length
- Password complexity
- Password topologies

Implement Secure Password Recovery Mechanism

It is common for an application to have a mechanism that provides a means for a user to gain access to their account in the event they forget their password.

Store Passwords in a Secure Fashion

It is critical for an application to store a password using the right cryptographic technique.

Transmit Passwords Only Over TLS or Other Strong Transport

- The login page and all subsequent authenticated pages must be exclusively accessed over Transport Layer Security (TLS) or other strong transport.
- The initial login page, referred to as the "login landing page", must be served over TLS or other strong transport.

Require Re-authentication for Sensitive Features

- Require the current credentials for an account before updating sensitive account information (password, email) or before sensitive transactions (shipping a purchase to a new address).

Require Re-authentication for Sensitive Features

- Attacker may be able to execute sensitive transactions through a Cross-Site Request Forgery (CSRF) or Cross-site Scripting (XSS) attack without needing to know the user's current credentials.

Require Re-authentication for Sensitive Features

- Attacker may also get temporary physical access to a user's browser or steal their session ID to take over the user's session.

Consider Strong Transaction Authentication

Some applications should use a second factor to check whether a user may perform sensitive operations.

Authentication and Error Messages

- **Incorrectly implemented error messages in the case of authentication functionality can be used for the purposes of user ID and password enumeration.**
- An application should respond (both HTTP and HTML) in a generic manner.

Authentication and Error Messages

- Incorrectly implemented error messages in the case of authentication functionality can be used for the purposes of user ID and password enumeration.
- **An application should respond (both HTTP and HTML) in a generic manner.**

Authentication and Error Messages

- An application should respond with a generic error message regardless of whether the user ID or password was incorrect.
- It should also give no indication to the status of an existing account.

Image source: Sesame Street/Sesame Workshop

Authentication and Error Messages

- **Incorrect Response Examples**
  - **"Login for User foo: invalid password"**
  - **"Login failed, invalid user ID"**
  - **"Login failed; account disabled"**
  - **"Login failed; this user is not active"**
- Correct Response Example
  - "Login failed; Invalid user ID or password"

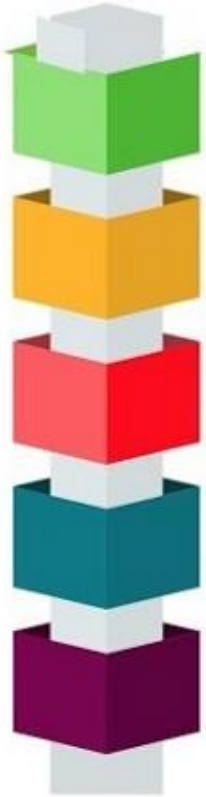
Authentication and Error Messages

- Incorrect Response Examples
  - "Login for User foo: invalid password"
  - "Login failed, invalid user ID"
  - "Login failed; account disabled"
  - "Login failed; this user is not active"
- **Correct Response Example**
  - **"Login failed; Invalid user ID or password"**

Authentication and Error Messages

- The application may return a different HTTP Error code depending on the authentication attempt response.
- It may respond with a 200 for a positive result and a 403 for a negative result.
- Even though a generic error page is shown to a user, the HTTP response code may differ which can leak information about whether the account is valid or not.

HTTP Status Codes



1XX
INFORMATIONAL

2XX
SUCCESS

3XX
REDIRECTION

4XX
CLIENT ERROR

5XX
SERVER ERROR

Image source: https://miro.medium.com/max/875/1*w_iicbG7L3xEQTArjHUS6g.jpeg

Prevent Brute-Force Attacks

- **If an attacker can guess passwords without the account becoming disabled due to failed authentication attempts, the attacker has an opportunity to continue with a brute force attack until the account is compromised.**
- Password lockout mechanisms should be employed that lock out an account if more than a preset number of unsuccessful login attempts are made.

Prevent Brute-Force Attacks

- If an attacker can guess passwords without the account becoming disabled due to failed authentication attempts, the attacker has an opportunity to continue with a brute force attack until the account is compromised.
- **Password lockout mechanisms should be employed that lock out an account if more than a preset number of unsuccessful login attempts are made.**

Prevent Brute-Force Attacks

- **Multi-factor authentication is a very powerful deterrent when trying to prevent brute force attacks since the credentials are a moving target.**
- When multi-factor is implemented and active, account lockout may no longer be necessary.

Prevent Brute-Force Attacks

- Multi-factor authentication is a very powerful deterrent when trying to prevent brute force attacks since the credentials are a moving target.
- **When multi-factor is implemented and active, account lockout may no longer be necessary.**

Logging and Monitoring

Logging and Monitoring

- **Enable logging and monitoring of authentication functions to detect attacks / failures on a real time basis**
  - Ensure that all failures are logged and reviewed

Image source: https://images.medicaldaily.com/sites/medicaldaily.com/files/2014/06/10/journal-writing.jpg

Logging and Monitoring

- Enable logging and monitoring of authentication functions to detect attacks / failures on a real time basis
  - **Ensure that all failures are logged and reviewed**

Image source: https://images.medicaldaily.com/sites/medicaldaily.com/files/2014/06/10/journal-writing.jpg

Logging and Monitoring

- Enable logging and monitoring of authentication functions to detect attacks / failures on a real time basis
  - **Ensure that all password failures are logged and reviewed**

Image source: https://images.medicaldaily.com/sites/medicaldaily.com/files/2014/06/10/journal-writing.jpg

Logging and Monitoring

- Enable logging and monitoring of authentication functions to detect attacks / failures on a real time basis
  - **Ensure that all account lockouts are logged and reviewed**

Image source: https://images.medicaldaily.com/sites/medicaldaily.com/files/2014/06/10/journal-writing.jpg

Use of authentication protocols that require no password

OpenID
Connect

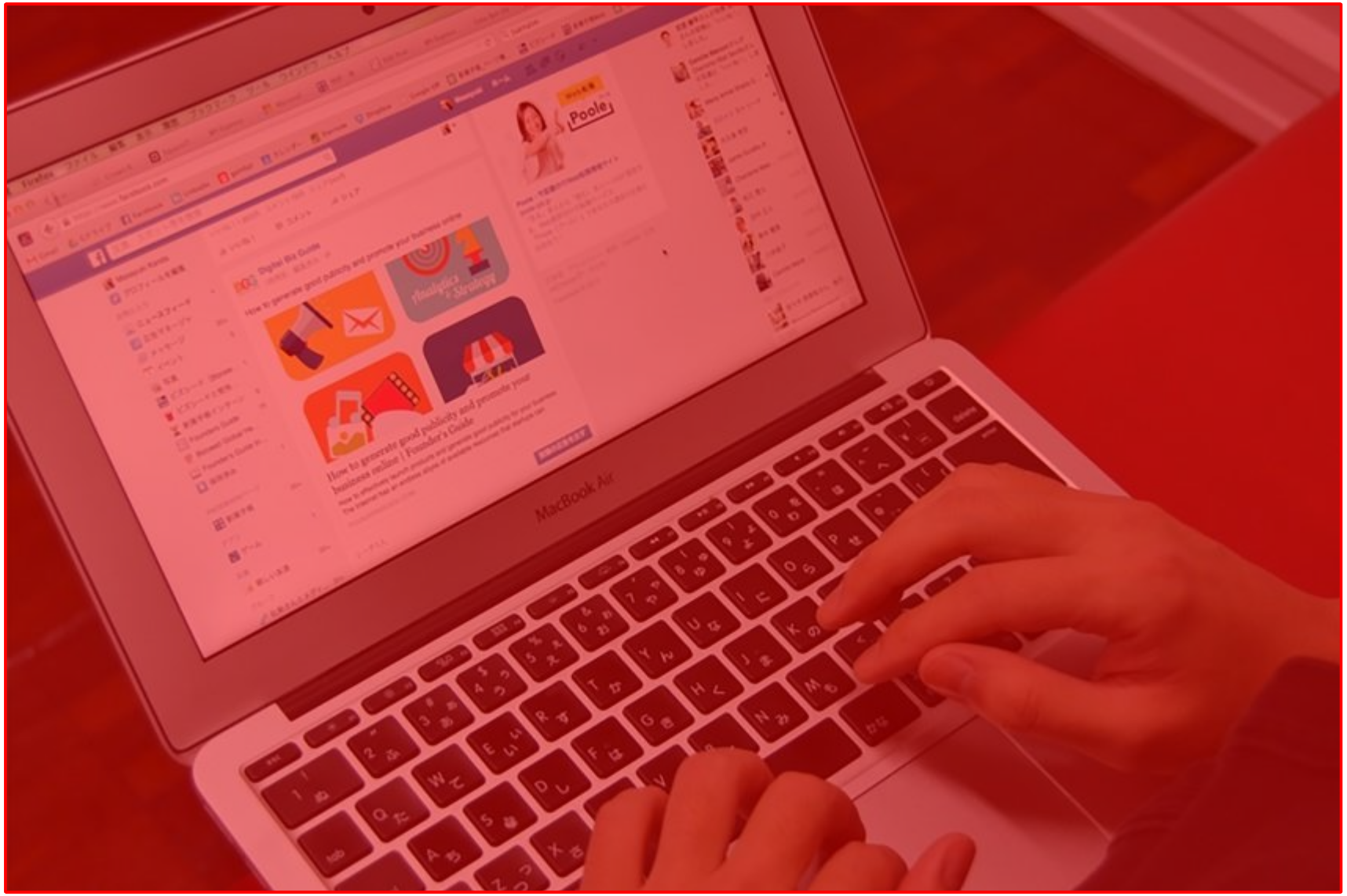
OAUTH
2
OAUTH

Use of authentication protocols that require no password

- While authentication through a user/password combination and using multi-factor authentication is considered generally secure, there are use cases where it isn't considered the best option or even safe.
  - Example: Third party applications that desire connecting to the web application, either from a mobile device, another website, desktop or other situations.

Use of authentication protocols that require no password

- While authentication through a user/password combination and using multi-factor authentication is considered generally secure, there are use cases where it isn't considered the best option or even safe.
  - **Extends the attack surface into their hands, where it isn't in your control.**


MacBook Air

Log in
Email
Password
Forgot your pass rd?
Log me in!
Rememb
We'll never post anything
MacBook Air
5VS ACTION GAMEPLAY

Additional Reading/Videos

- "What's wrong with your pa$$word?" by Lorrie Faith Cranor
  - https://www.ted.com/talks/lorrie_faith_cranor_what_s_wrong_with_your_pa_word?language=en
- HTTP Status Codes
  - https://www.restapitutorial.com/httpstatuscodes.html
- What is Attack Surface Analysis and Why is it Important
  - https://cheatsheetseries.owasp.org/cheatsheets/Attack_Surface_Analysis_Cheat_Sheet.html

AUTHENTICATION

SECURE WEB DEVELOPMENT